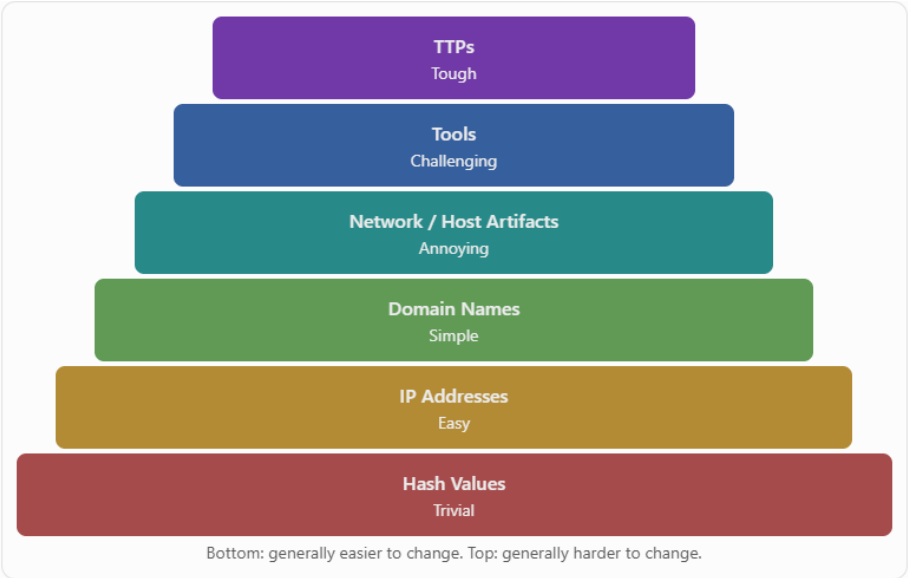
TryHackMe Writeup 7: Pyramid of Pain

Room: Cyber Threat Intelligence (CTI), indicators of compromise (IOCs), threat hunting, incident response, MITRE ATT&CK

Objective: Understand how threat intelligence helps defenders detect malicious activity and how different indicators vary in the effort required for an attacker to change them

Step 1 – Understand the Pyramid of Pain
The Pyramid of Pain ranks indicators according to how difficult they are for an attacker to change when defenders detect or block them.



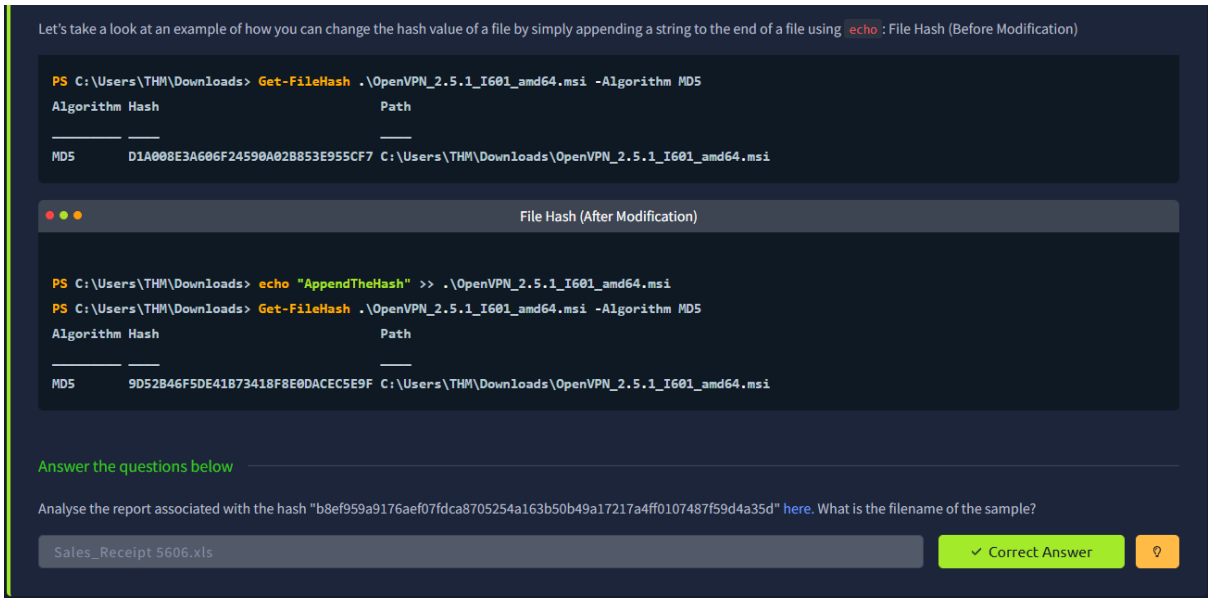
Step 2 - Study hash values
A hash is a fixed-length output generated from data using a hash function.
Examples include MD5, SHA-1, and SHA-256.

A defender might identify a malicious file by its SHA-256 hash. However, if the attacker modifies the file, the new file may have a different hash.

For the room's sample-analysis exercise:

1. Open the report linked in the task.
2. Find the report associated with the specified hash.
3. Inspect the file or sample information.
4. Record the filename requested by the room.

Key point: Hashes are useful for identifying known files, but hash-based detection alone can be fragile.

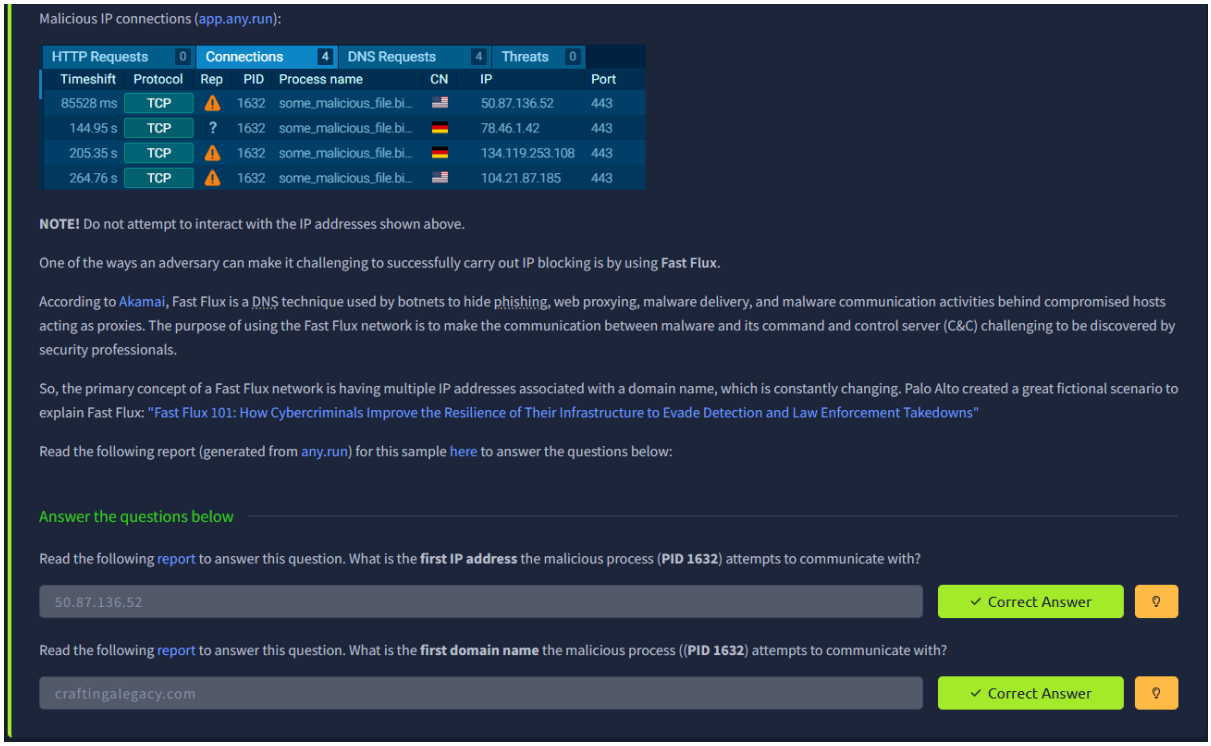


Step 3 - Study IP addresses

Malware may connect to an IP address associated with command-and-control infrastructure.

1. Open the sandbox report linked by the room.
2. Find the process identified in the question.
3. Inspect its network connections.
4. Record the first IP address it attempts to contact.
5. Follow the same procedure for the first domain name requested.

Do not visit suspicious addresses or execute malware samples on your own device. Use the report's existing analysis data.



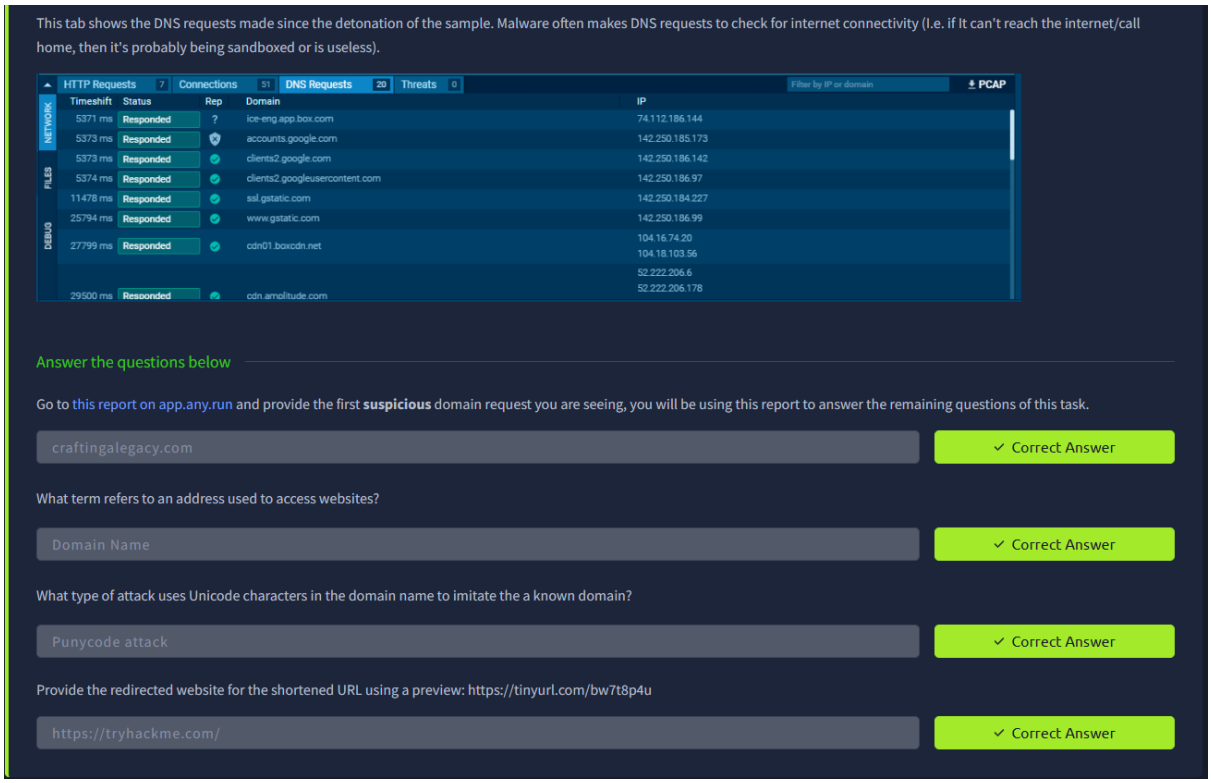
Step 4 - Study domain names
Domain names provide human-readable names for internet services.
Defenders can investigate suspicious domains using DNS records, threat intelligence, and sandbox reports.

The room also introduces:

- Suspicious domain requests.
- URL shorteners and redirect destinations.
- Unicode lookalike domains and Punycode attacks.

A Punycode-based homograph attack uses internationalized domain-name characters to make a deceptive domain resemble a legitimate one.

For a URL-shortener question, use the preview method described in the room or inspect the destination in a safe analysis environment. Do not open unknown destinations on a system containing sensitive accounts.



Step 5 - Study host and network artifacts
Artifacts are clues left by a process or its network activity.

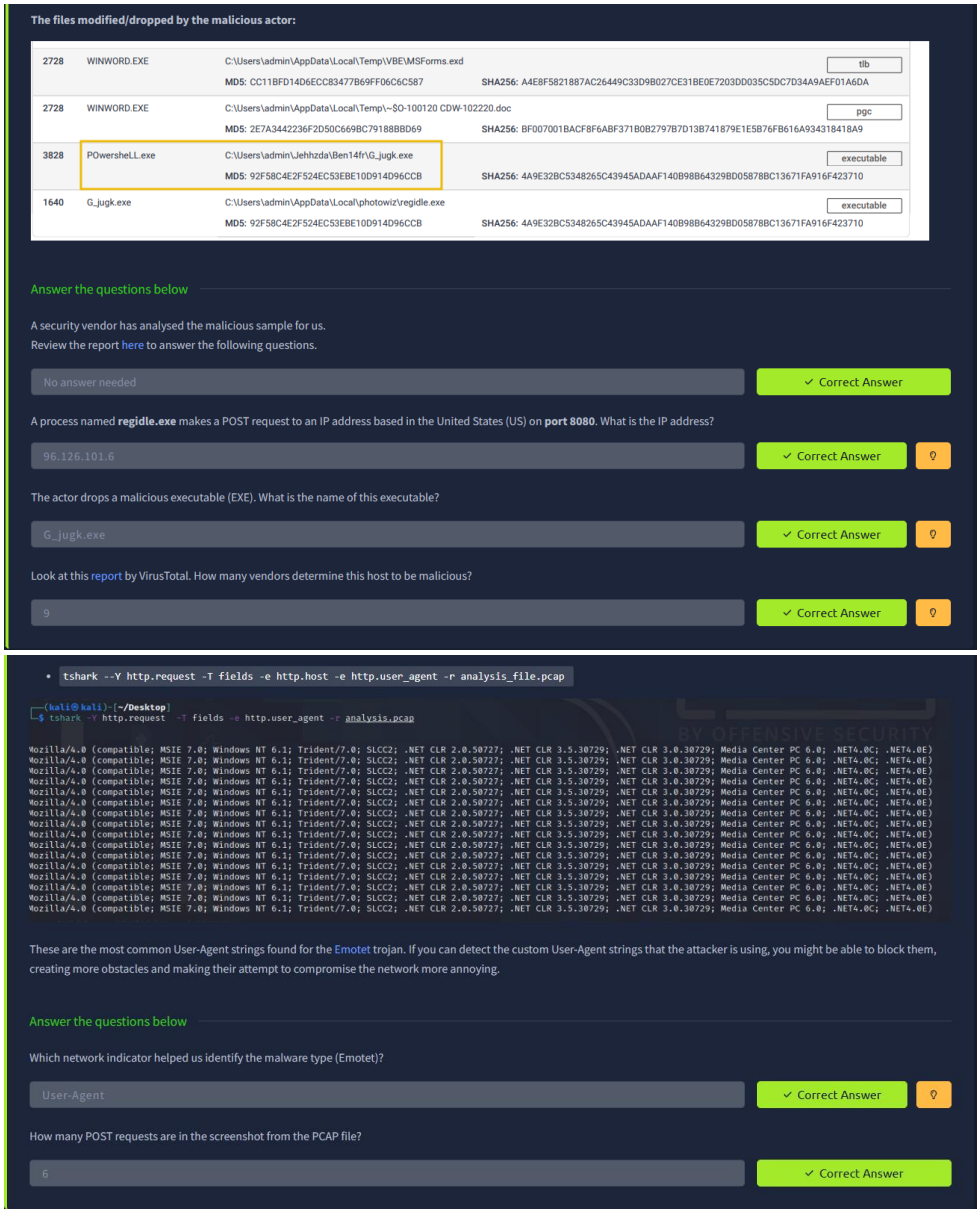
Examples include:

- Unexpected files or registry changes.
- Suspicious HTTP request paths.
- Unusual User-Agent strings.

- Unexpected process execution.
- Connections to suspicious infrastructure.

For a network-artifact question:

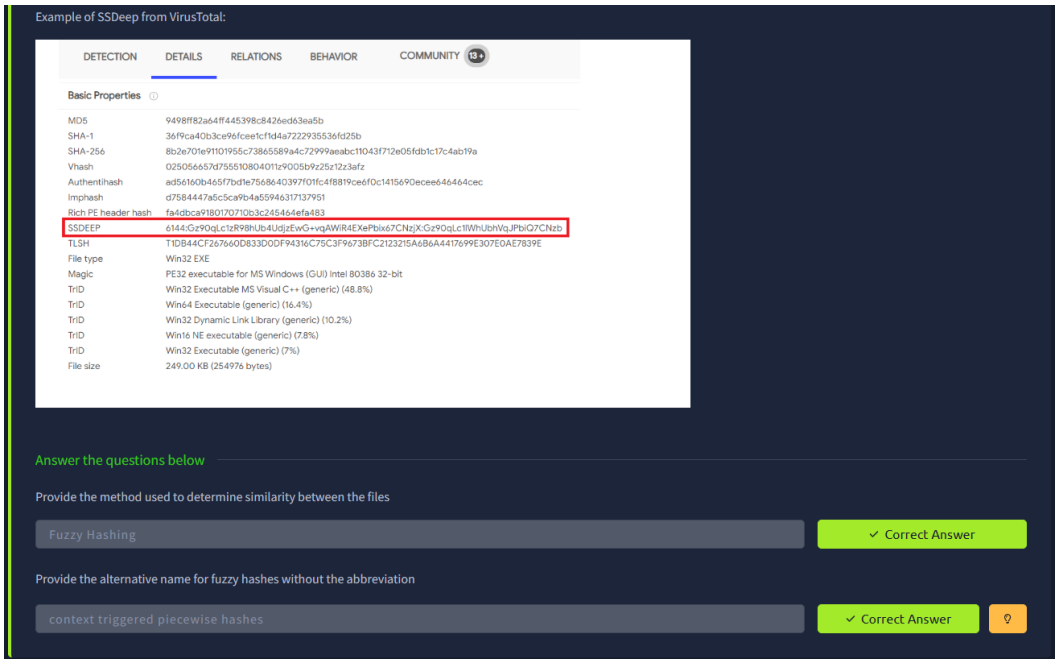
1. Read the report or packet-capture evidence provided.
2. Inspect the relevant HTTP requests.
3. Identify the indicator highlighted by the task.
4. Count any requests when the question asks for a number.

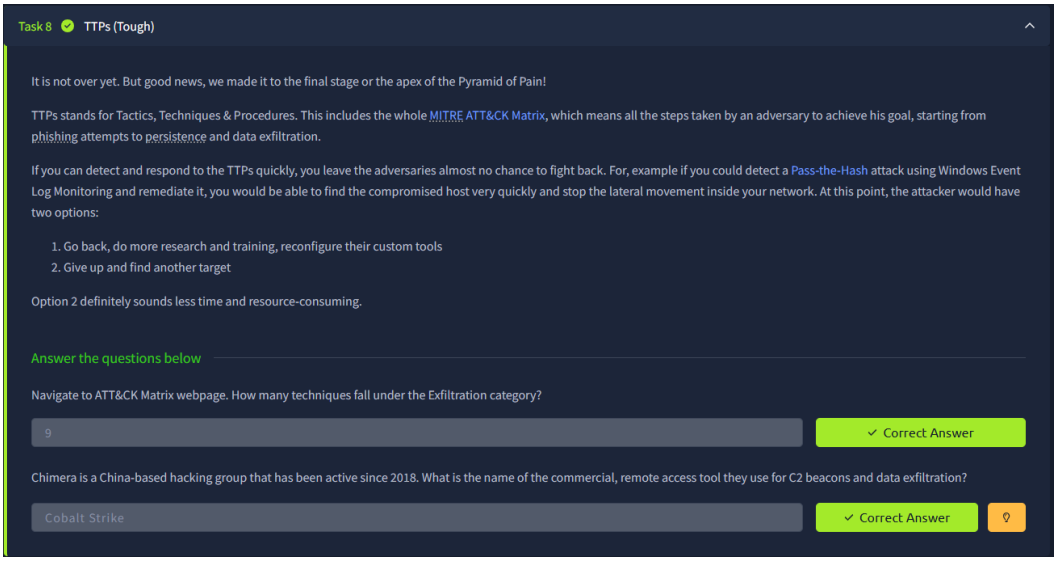


Step 6 - Understand tools and TTPs

Tools are the software used by an attacker. Detecting a tool can force an attacker to replace or reconfigure it.

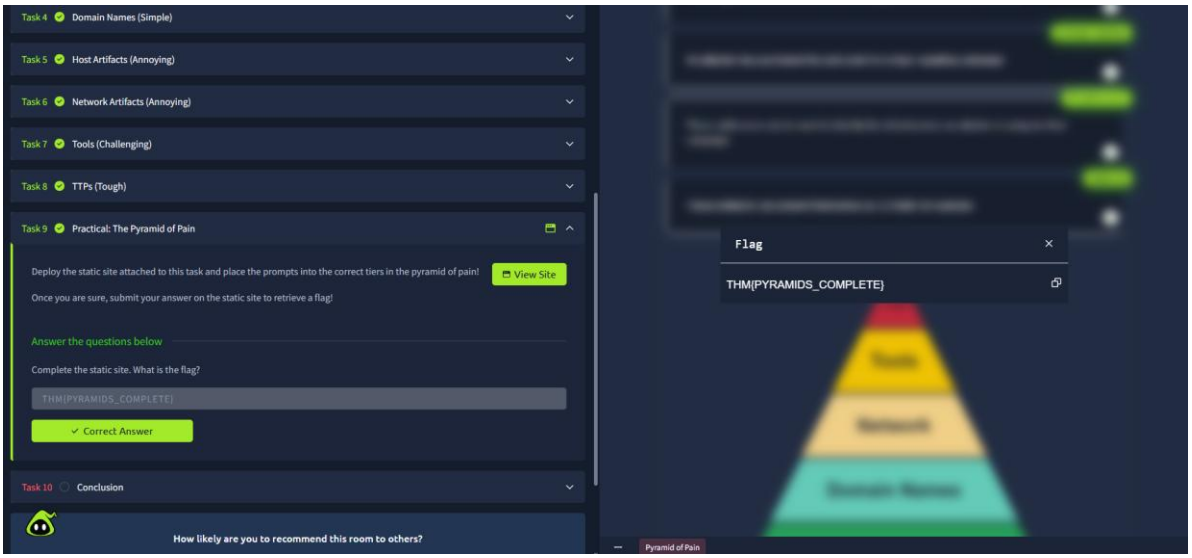
TTPs means tactics, techniques, and procedures. These describe the adversary's objectives and behavior, rather than just a file or network indicator.





Step 7 - Complete the practical task

1. Review the evidence in the provided reports.
2. Identify each requested indicator.
3. Match each indicator to its pyramid level.
4. Apply the concepts to the practical scenario.
5. Submit your answers and verify completion.



What you should learn: Effective threat hunting goes beyond collecting hashes and IP addresses. Behavioral detection and understanding attacker techniques can provide more resilient defenses.

